ENTERPRISE AI GOVERNANCE & ASSURANCE PLATFORM

RedTeam AI Labs

Test, Govern, and Assure Your AI Before Your Users Do.

Automated adversarial red-teaming, quantitative risk scoring, and statutory compliance cross-walking for high-liability autonomous AI systems.

`Next.js 14 Standalone` `Supabase PostgreSQL (RLS)` `Google Gemini Dual Engine` `NIST AI RMF 1.0` `EU AI Act Reg. 2024/1689`

Founder: Sulisumen Peter | **GitHub:** github.com/sulisumenpeter/RedTeam-AI-Labs

THE PROBLEM

The Enterprise AI Trust & Accountability Crisis

TECHNICAL RISK

1. Production Failure Modes

- Generative LLMs hallucinate fictitious statutes, citations, and factual claims in customer interactions.
- Models leak internal routing keys, API credentials, and system instructions under social engineering.
- Subtle demographic & socioeconomic bias creates severe disparate treatment and customer harm.
- Autonomous agents take destructive or unlawful actions when prompted outside safe guardrails.

STATUTORY LIABILITY

2. Regulatory Enforcement Wave

- **EU Artificial Intelligence Act:** Enforces mandatory pre-deployment testing and risk management.
- **Enormous Fines:** Non-compliance penalties reach up to €35M or 7% of worldwide annual turnover.
- **NIST AI RMF & ISO 42001:** Demand continuous empirical risk governance and traceable human oversight.
- **Professional Ethics:** Bar associations enforce non-delegable supervision duties on AI legal workflows.

MARKET GAP

3. The Governance Tooling Vacuum

- **Legacy GRC Platforms (OneTrust, Vanta):** Track static checklists and questionnaires that never test models.
- **Raw Pentesting Scripts (Promptfoo, Giskard):** Lack enterprise RBAC, multi-tenancy, and regulatory mappings.
- Enterprises either freeze AI rollouts or deploy blind with immense regulatory and malpractice liability.

THE SOLUTION

Automated Policy-Driven Pre-Deployment AI Assurance

CORE ARCHITECTURAL TENET: 'THE LLM PROPOSES, THE BACKEND DISPOSES.'

Generative models are utilized to adversarially probe and semantically evaluate target models, but all risk calculations, severity dispositions, and policy gates are strictly executed by deterministic backend rules in PostgreSQL.

1. Catalog & Classify

- Central model registry.
- Owner & deployment tier tracking.
- EU AI Act risk categorization (Minimal, Limited, High, Unacceptable).

2. Bind Policies

- Immutable policy versioning.
- Direct cross-walks to NIST AI RMF, ISO 42001, and EU AI Act.
- Audit-traceable requirement IDs.

3. Adversarially Fuzz

- Dynamic multi-strategy fuzzing.
- 1 anchor + 4 variants per rule.
- Paired socioeconomic bias testing.
- Sub-20s parallel compilation.

4. Attest & Export

- 1-click incident promotion.
- Assign corrective action plans.
- SHA-256 evidence vault.
- Export PDF, HTML, JSON audit packs.

PLATFORM CAPABILITIES

Six Integrated Enterprise Governance Modules

1. AI System Inventory

- Centralized model metadata cards.
- Purpose, user populations, & deployment tier.
- EU AI Act risk tier tag (High-Risk intake).

2. AI Risk Register

- Interactive 5×5 Likelihood x Impact heat matrix.
- PostgreSQL generated inherent & residual scores.
- Actionable mitigation plan tracking.

3. Governance & Frameworks

- NIST AI RMF 1.0 (Govern, Map, Measure, Manage).
- EU AI Act Articles 9, 13, 14 cross-walks.
- ISO/IEC 42001:2023 & OECD AI Principles.

4. Adversarial Red-Team Engine

- 10 test categories (Injection, Leakage, Bias).
- Paired differential socioeconomic testing.
- Target adapters for Synthetic and External APIs.

5. Incidents & Remediation

- 1-click finding-to-incident promotion.
- Assign corrective actions: Guardrails, Retraining.
- Automated regression testing verification loop.

6. Evidence Vault & Reports

- Tamper-evident SHA-256 cryptographic records.
- Append-only audit trail logging every event.
- One-click export to PDF, HTML, and JSON bundles.

TECHNICAL ARCHITECTURE

Engineered for Zero-Trust Auditing & Security

FULL-STACK FOUNDATION

Modern Scalable Stack

- **Next.js 14 App Router** with standalone compilation.
- **Supabase PostgreSQL** with Row Level Security (RLS).
- **Database Generated Columns:** Inherent and residual risk computed in PostgreSQL engine.
- **Foreign Key Cascades:** Relational integrity preserved on all deletions.
- **Parallelized Generation:** Compiles 30-test plans concurrently in under 20 seconds.

DUAL AI ENGINE

Hybrid Evaluation Pipeline

- **Deterministic Evaluator:** Instant regex/pattern matching for credential leaks, eviction advice, overrides.
- **Semantic Evaluator:** Gemini Pro structured evaluation over subtle contextual nuances.
- **Prompt Injection Shield:** Evaluator input wrapped in [UNTRUSTED TARGET DATA] delimiters.
- **Deterministic Severity Mapper:** Reconciles signals; LLMs never unilaterally assign critical scores.

ZERO-TRUST APPSEC

Hardened Infrastructure

- **Kernel-Level SSRF Guard:** Blocks loopbacks, RFC-1918 IPs, and cloud metadata (169.254.169.254).
- **IP Evasion Defense:** Blocks decimal-encoded IPs (e.g. 2130706433), IPv6 loopbacks, admin ports.
- **Enterprise RBAC:** 4 roles (Owner, Admin, Assessor, Viewer) with workspace isolation.
- **Session Shield:** Resilient cookie management during upstream rate limits.

MARKET & OPPORTUNITY

Initial Beachhead: Legal AI & High-Liability Verticals

INITIAL BEACHHEAD

Legal AI & Legal Technology

- **Extreme Malpractice Liability:** An AI assistant hallucinating statutes or advising eviction lockouts commits unauthorized practice of law (UPL) and statutory breach.
- **Mandatory Professional Ethics:** Bar association rules enforce non-delegable duties of lawyer supervision over non-lawyer and AI tools.
- **High Willingness to Pay:** Law firms, legal tech SaaS vendors, and legal clinics cannot deploy client-facing AI without empirical safety proof.
- **Built-in Demonstration Model:** Synthetic Legal Intake Assistant modeled on real-world eviction, tenant disclosures, and fee agreements.

EXPANSION VERTICALS

Regulated Enterprise AI Sectors

- **Financial Services & Fintech:** Algorithmic underwriting, wealth management bots, automated KYC/AML conversational bots (FCRA & CFPB compliance).
- **Healthcare & Clinical Intake:** Patient triage bots, clinical documentation tools, medical disclosure verification (HIPAA & FDA oversight).
- **HR & Talent Intelligence:** Automated candidate screening and compensation analytics (anti-bias & EEOC disparate impact compliance).
- **Enterprise Customer Service:** Autonomous customer-facing agents with access to transactional databases.

COMMERCIAL MODEL (PROPOSED)

B2B SaaS with Usage-Based Assurance Expansion

COMMUNITY

Free Pilot

$0

- Individual devs & researchers.
- Preconfigured baseline policies.
- Synthetic target testing.
- Up to 50 test runs/mo.

GROWTH

Professional

$499 /mo

- Legal tech startups & boutique firms.
- Custom policy builder.
- External API endpoint probing.
- 5 team seats & PDF exports.

SCALE

Enterprise

$2,500+ /mo

- Large law firms & corporate legal.
- Multi-workspace isolation & SSO.
- Full statutory export bundles.
- Dedicated cryptographic audit vault.

CHANNEL

Auditor Seat

$999 /seat

- Compliance consultants & auditors.
- Multi-client tenant views.
- White-labeled audit bundles.
- Verification seal generation.

**Transparency Note: Subscription tiers and pricing figures represent proposed commercialization models subject to customer validation during initial pilot design partnerships.*

COMPETITIVE DIFFERENTIATION

Why RedTeam AI Labs Wins: Active Testing Meets Governance

ACTIVE VS STATIC

Versus Legacy GRC (OneTrust, Vanta)

- **The GRC Limitation:** GRC tools track static paper promises and checkboxes. They have zero capability to execute prompts or inspect model outputs.
- **RedTeam AI Labs:** We actively test live models with multi-strategy adversarial attacks, producing empirical evidence of compliance rather than self-reported assertions.
- Automated 5×5 mathematical risk scoring linked directly to live test findings.

ENTERPRISE VS CLI

Versus CLI Fuzzers (Promptfoo, Giskard)

- **The CLI Limitation:** Developer CLI tools run isolated test scripts but lack enterprise governance, risk registers, and business workflows.
- **RedTeam AI Labs:** Full relational enterprise platform with multi-tenant workspaces, 4-tier RBAC, incident tracking, and cryptographic evidence vaults.
- Direct cross-walking to EU AI Act, NIST AI RMF, and ISO 42001 statutory standards.

DEFENSIBLE MOATS

Our Unique Competitive Moats

- **1. Policy-to-Test Determinism:** Every test case is derived from an immutable governance requirement.
- **2. 'LLM Proposes, Backend Disposes':** Zero hallucinated passes or unvetted scoring.
- **3. Paired Bias Differentials:** Automated detection of subtle socioeconomic disparate treatment.
- **4. Cryptographic Proof:** Tamper-evident SHA-256 evidence bundles suitable for external legal audit.

TRACTION & PROGRESS

Working Codebase, Validated Architecture, Zero Regressions

QUALITY

100% Test Pass Rate

46 / 46

- Unit & security regression tests passing across 11 test suites.
- Verified RBAC, rate limiting, SSRF evasion, and risk scoring.

BROWSER E2E

Playwright E2E Suite

15 / 15

- 15 end-to-end browser tests passing against live production server.
- Complete campaign audit workflow executed in 2.8 minutes.

LIVE AI

Real Gemini Integration

- Live API integration verified with Google Gemini models.
- Parallelized execution compiling test plans in under 20s.

PERSISTENCE

18 PostgreSQL Tables

- Active Supabase relational database persistence.
- PostgreSQL generated columns computing scores in engine.

ZERO ERRORS

Clean Standalone Build

- Next.js 14 production compilation succeeding cleanly.
- Zero browser console errors across all 7 dashboard sections.

MILESTONE

Fellowship Recognition

- Evaluated and demonstrated at the LexHack Builders Fellowship.
- Open-source codebase on GitHub with clean commit history.

STRATEGIC ROADMAP

3–6 Month Product & Commercial Roadmap

MONTHS 1–2

Multi-Cloud & Ecosystem

- **Cloud Adapters:** Build native adapters for AWS Bedrock & Azure AI Foundry.
- **Model Expansion:** Add Anthropic Claude 3.5 Sonnet and Meta Llama 3 models.
- **CI/CD Integration:** Release automated GitHub Actions Red-Teaming Action.
- **Quota Scaling:** Upgrade Gemini API integration to enterprise tier.

MONTHS 3–4

Design Partner Pilots

- **Pilot Program:** Deploy structured pilots with 3–5 legal tech startups and legal clinics.
- **Ethics Templates:** Pre-built policy templates for Bar Association ethics compliance.
- **Compliance Audit:** Conduct formal SOC 2 Type I readiness assessment.
- **UX Optimization:** Refine workflows based on enterprise risk officer feedback.

MONTHS 5–6

Commercial Launch

- **Self-Serve Billing:** Roll out Stripe billing and subscription management.
- **Alerting:** Real-time webhook alerting (Slack, Microsoft Teams, PagerDuty).
- **Continuous Ops:** Scheduled continuous regression testing for deployed APIs.
- **Vertical Expansion:** Expand footprint into clinical intake and financial services.

THE ASK

Accelerating Development Through Compute & Partnerships

INFRASTRUCTURE

Cloud & AI Startup Programs

- **AWS Activate:** Cloud credits and AWS Bedrock foundation model API access.
- **Microsoft for Startups Founders Hub:** Azure OpenAI service credits and enterprise compliance support.
- **Google for Startups Cloud Program:** Vertex AI enterprise access to upgrade from free-tier limits.
- **Model Grants:** Dedicated developer API access from OpenAI and Anthropic.

DESIGN PARTNERS

Pilot & Advisory Partnerships

- **3–5 Legal Tech Design Partners:** Validate pre-deployment testing on client-facing assistants.
- **Law Firm Innovation Groups:** Test contract analysis and legal intake triage bots.
- **Advisory Engagement:** Mentorship from enterprise CISOs, AI safety researchers, and regulatory attorneys.

CAPITAL ALLOCATION FOCUS

45% AI Compute & Cloud Infrastructure (High-throughput adversarial fuzzing campaigns across enterprise LLMs) • **35% Core Engineering & Security Auditing** (Multi-cloud adapters, CI/CD actions, SOC 2 preparation) • **20% Pilot Deployment & Community Engagement** (Supporting pilot cohorts, open-source policy benchmarks).

VISION & CONTACT

The Operating System for Enterprise AI Trust

The Mandatory Assurance Layer for Autonomous AI

- **The Inevitable Category:** Datadog became indispensable for cloud observability. Vanta automated security compliance. RedTeam AI Labs will be the mandatory assurance layer every enterprise executes before deploying AI.
- **Working, Verified Technology:** 100% automated test pass rate across 61 unit and E2E checks with live AI generation.
- **Massive Market Pull:** Global regulatory enforcement (EU AI Act, NIST AI RMF, ISO 42001) makes empirical AI safety testing a statutory mandate.
- **Clear Beachhead:** Starting in high-liability Legal AI, expanding across healthcare, fintech, and enterprise SaaS.

PARTNER WITH US TO BUILD AUDITABLE, TRUSTWORTHY AI

Founder: Sulisumen Peter | **Product:** RedTeam AI Labs | **GitHub:** https://github.com/sulisumenpeter/RedTeam-AI-Labs

Open for Startup Accelerators, Fellowship Applications, AI Infrastructure Grants & Pilot Design Partnerships.